UMG · INFORMÁTICA I · SEMANA 11 · CAPS. 8 Y 9

Herramientas de seguridad y privacidad de datos

De la contraseña al DPI: el blindaje que protege sin frenar el negocio

Ruldin Ayala · Administración de Empresas · 2026

Hoy: conceptos (30 min) → casos (15 min) → página + parejas 40 min

Guía estricta Caps. 8–9 del libro · Montos en quetzales con fin didáctico

Flujo de la clase de hoy

1 · CONCEPTOS
(30 min)

Autenticación, MFA, ACL/RBAC, cifrado, firewall/VPN, backups, IDS, PUA, PII.

Todo del libro, con ejemplo del texto.

2 · CASOS GT
(15 min)

Cooperativa, retail, distribuidora y clínica: ¿qué herramienta falló y cuánto cuesta?

3 · PÁGINA S11
(40 min parejas)

10 misiones interactivas + 4 casos piloto/copiloto + PDF Canvas + tarea individual.

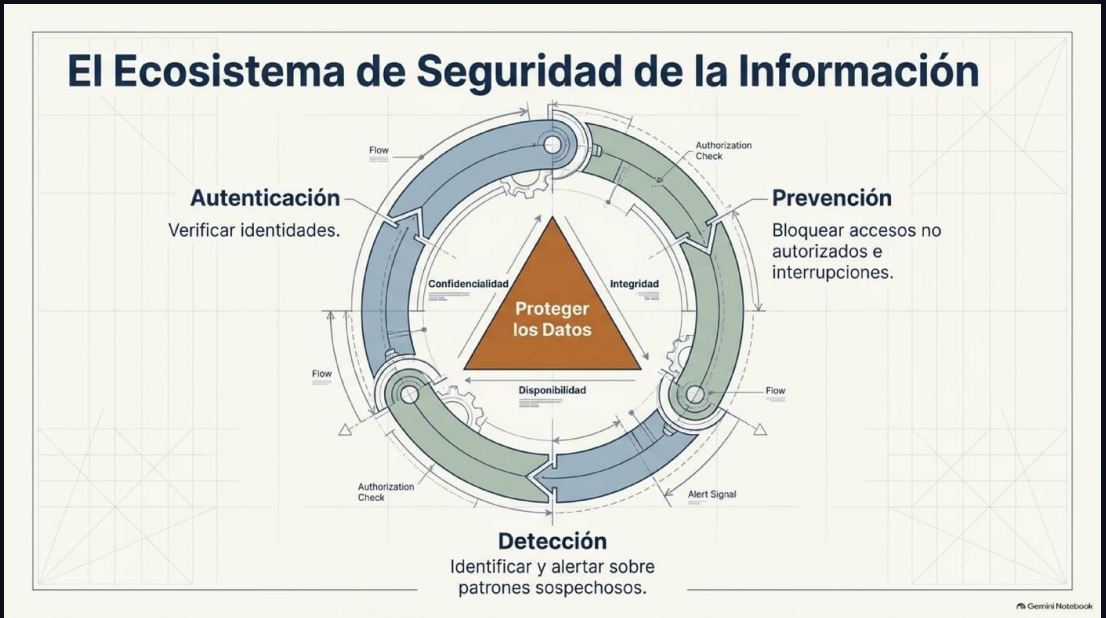
El ecosistema: proteger los datos

Objetivo: confidencialidad + integridad + disponibilidad CIA

AUTENTICACIÓN: verificar identidades.

PREVENCIÓN: bloquear accesos no autorizados e interrupciones.

DETECCIÓN: identificar y alertar patrones sospechosos.



Autenticación: tres factores

Asegura que quien accede sea quien afirma ser

1 · ALGO QUE SE SABE: usuarios, contraseñas, PIN, preguntas OOW.

2 · ALGO QUE SE POSEE: tarjetas, llaves, tokens RSA de código dinámico.

3 · ALGO QUE SE ES: retina, huellas, geometría facial.



Cap. 8.4 · Figura: Estrategia de Seguridad Digital

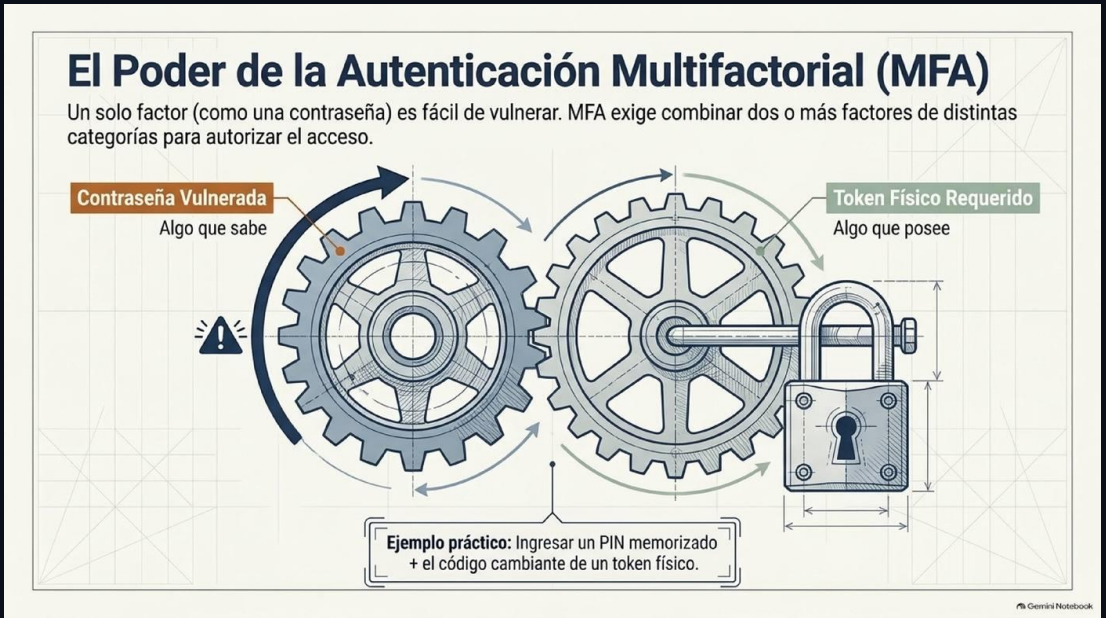
MFA: un factor se vulnera

La autenticación multifactorial exige 2+ factores de distintas categorías

Una sola contraseña es fácil de vulnerar.

MFA combina categorías distintas.

Ejemplo: PIN memorizado (sabe) + código del token físico (posee).

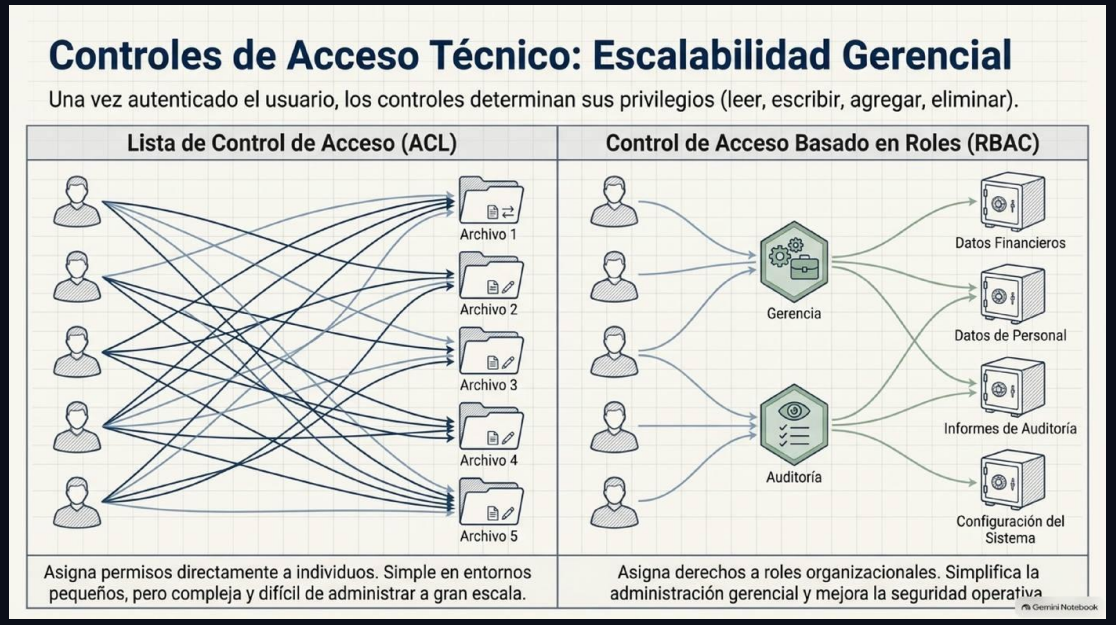


Controles de acceso: ACL vs RBAC

Autenticado el usuario, definen privilegios: leer, escribir, agregar, eliminar

ACL: permiso directo por persona y recurso. Simple en pequeño, compleja a escala. (**caso B del retail: 200 reglas y un ex-empleado que siguió entrando)**

RBAC: derechos a ROLES (Auditor, Gerente de Ventas) y personas a roles. Simplifica y da seguridad operativa.
Misión 4 tiene el slider: con 40 empleados la ACL pide 320 reglas y RBAC unas 48.



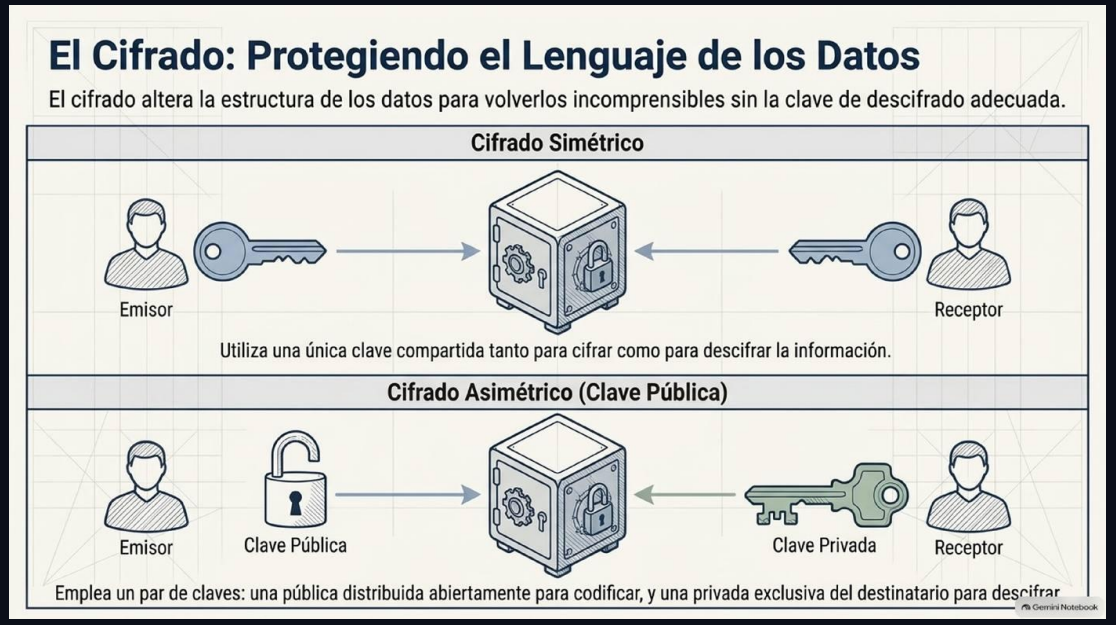
Cifrado: el lenguaje secreto

Altera los datos para volverlos incomprensibles sin la clave

SIMÉTRICO: una sola clave compartida para cifrar y descifrar.

ASIMÉTRICO (clave pública): pública abierta para cifrar + privada exclusiva del destinatario para descifrar.

Misión 5 cifra en vivo el mensaje del gerente en ambos modos.



Perímetro: firewall, VPN y antivirus

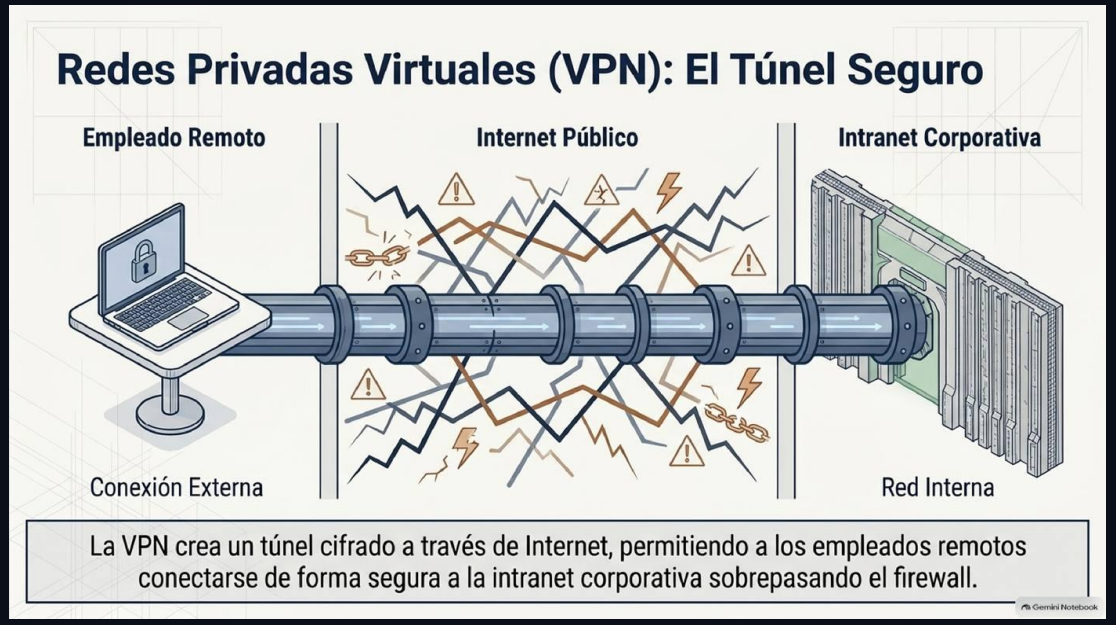
Bloquean el acceso no autorizado y protegen ante fallas

FIREWALL: inspecciona tráfico y bloquea paquetes fuera de regla.

VPN: túnel cifrado del remoto a la intranet, sobre el firewall.

ANTIVIRUS: monitorea, detecta y neutraliza software malicioso.

Ojo gerente: el firewall de la oficina NO ve el WiFi del café — por eso el caso C (vendedor espiado, pedido de Q22,000 perdido) exige VPN + cifrado. Misión 6 trae mini-firewall jugable y túnel VPN animado.



Resiliencia: el plan de desastres

Un buen respaldo es el que ya fue probado

1 · Copias periódicas de datos críticos.

2 · Almacenamiento OFFSITE, fuera del local.

3 · Pruebas continuas de restauración.

4 · UPS + sitios en caliente + redes SAN.



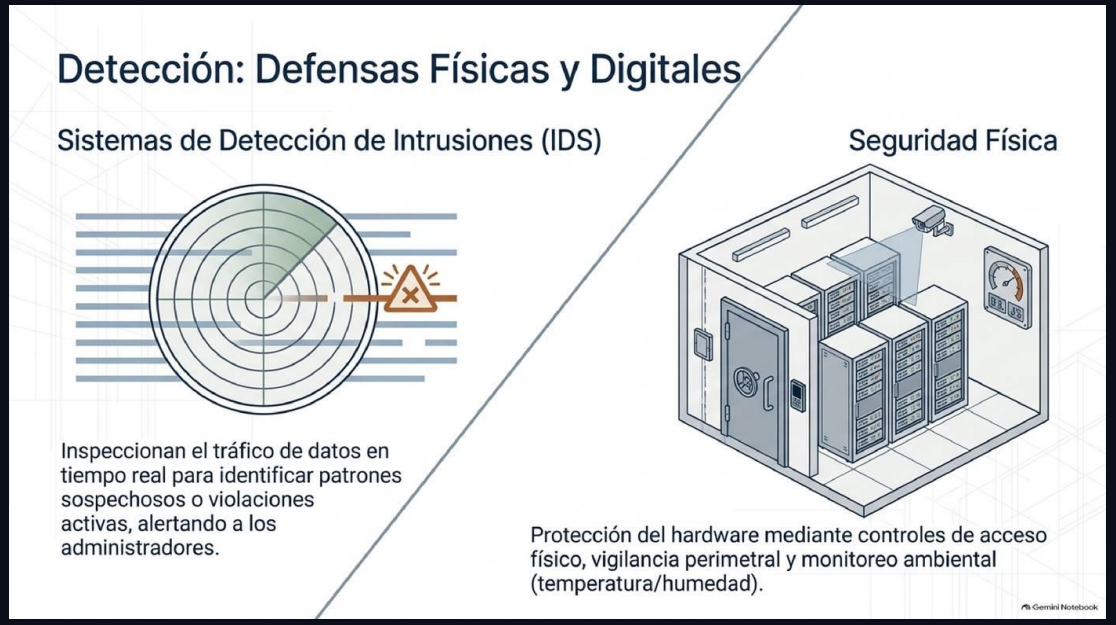
Cap. 8.5 · Figura: Estrategia de Seguridad Digital

Detección: IDS y seguridad física

Ver en tiempo real + proteger el fierro

IDS: inspecciona el tráfico en tiempo real, detecta patrones y violaciones, y ALERTA al administrador.

FÍSICA: puertas con cerradura, sensores, monitoreo de temperatura/humedad y vigilancia perimetral.



Políticas: sin reglas no hay técnica

La seguridad técnica es ineficaz sin reglas claras

POLÍTICA: documento formal de uso correcto + sanciones.

PUA: qué se permite y qué se prohíbe — no compartir credenciales, no alojar proyectos personales, no enviar masivos.

EQUILIBRIO: si el control estorba el trabajo, el usuario lo elude y el riesgo crece.



PII: lo que identifica a la persona

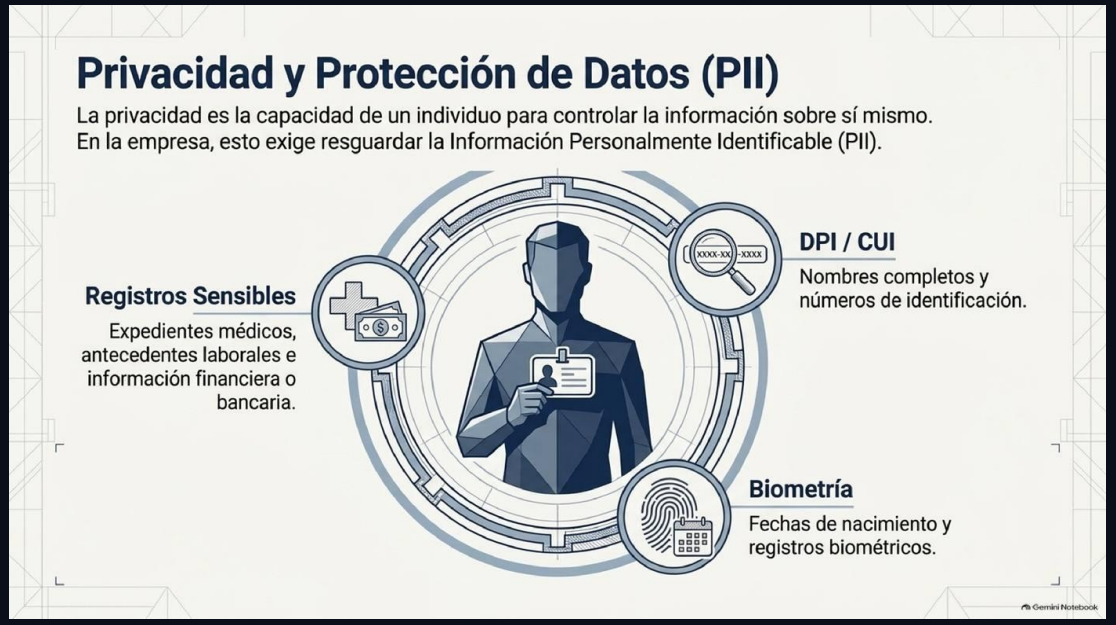
Privacidad = controlar la información sobre sí mismo

Resguarde la PII de clientes y empleados:

· Nombres + DPI/CUI.

· Nacimiento + registros biométricos.

· Expedientes médicos, laborales, financieros y bancarios.



Caps. 8.7 y 9.5 · Figura: Estrategia de Seguridad Digital

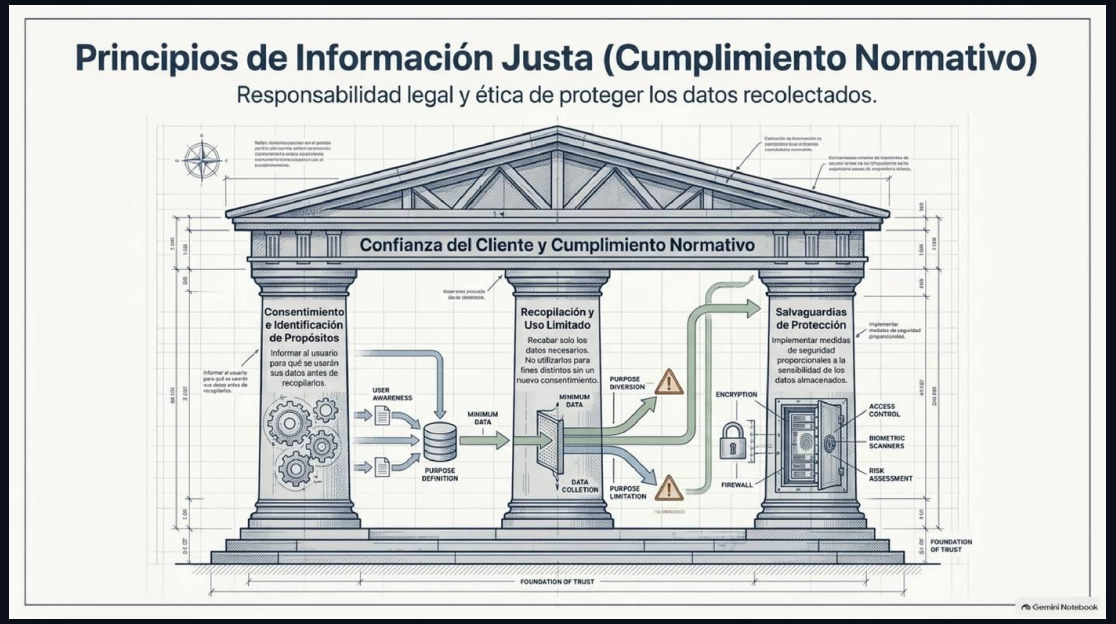
Principios justos y buenas prácticas

Responsabilidad legal y ética sobre los datos

PRINCIPIOS: consentimiento + propósito informado; solo datos necesarios, sin reúso; salvaguardas proporcionales.

EMPRESA: plan de incidentes, sistemas al día, cifrar portátiles y nube, capacitar siempre.

PERSONA: claves largas únicas, cambiarlas, 2FA y escepticismo ante enlaces.



Caps. 8.7 y 9.5 · Figura: Estrategia de Seguridad Digital

Casos de estudio: ¿qué falló?

Apliquen la teoría: herramienta + pilar CIA + costo en quetzales

A · Cooperativa sin MFA: solo contraseña, phishing y Q18,500 vaciados. ¿La app de código lo frenaba?

B · Retail con ACL caótica: 25 empleados, ex-vendedor activo y Q9,800 en devoluciones falsas.

C · Distribuidora sin VPN: planilla espiada en WiFi público, pedido de Q22,000 perdido.

D · Clínica con DPI en Excel + backup falso: IDS ignorado y rescate de Q24,000.

No los resolvemos aquí: los diagnostican en la página

A trabajar: página Semana 11

informática1/Semana11/Semana11CiberSeguridad2.html

MISIONES 1–10: ecosistema, contraseña, engranajes MFA, slider ACL/RBAC, cifrador, mini-firewall, túnel VPN, checklist 3-2-1, radar IDS, balanza y clasificador PII.

PAREJAS 40 MIN: piloto propone, copiloto cuestiona; investigan 5–10 min; guardan 4 casos; mentor IA valida; compromiso PUA + PDF Apellidos_Carnets_Sem11.pdf a Canvas.

TAREA: Silla del Gerente S11 (hotel de Antigua) individual con su PDF.

Cierre: el checklist del gerente

Antes de salir, su empresa debe tener:

MFA en banca, correo y ERP · RBAC con bajas inmediatas · VPN + cifrado en remoto · Backup 3-2-1 probado + UPS · PUA firmada sin genéricos · PII con consentimiento y mínimo.

Seguridad que estorba, se elude: blinde sin frenar el negocio.

Ruldin Ayala · UMG 2026 · Caps. 8–9 estrictos